【基本款42題】- 24461087 - 嘉瑪科技股份有限公司

顧問訂正前

分數 / 總分

263.7/352

加權分數	此次評級	檢測日期
74.915	**C**	**2026/10/19 13:45:15**

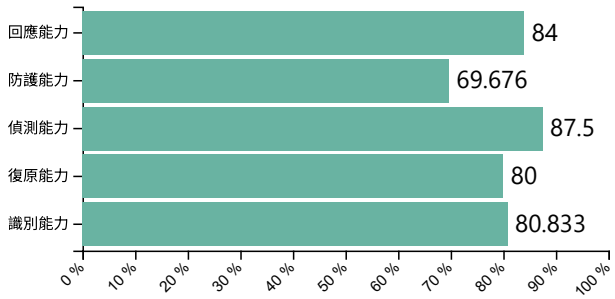
顧問訂正後

資安評級場域

分數 / 總分

加權分數	此次評級	檢測日期

顧問訂正前



顧問訂正後

回應能力(顧問訂正前)

分類	分數	評級
事件通報	84	B

防護能力(顧問訂正前)

分類	分數	評級
存取控制	64.714	D
資安意識與訓練	55	E
配置管理	74.762	C
身分驗證	82.143	B
系統和通訊保護	45	E
系統和資訊完整性	82.5	B

偵測能力(顧問訂正前)

分類	分數	評級
稽核和可歸責性	87.5	B

復原能力(顧問訂正前)

分類	分數	評級
復原	80	C

識別能力(顧問訂正前)

分類	分數	評級
風險管理	93.333	A
資安評估	68.333	D

題目2，參考標準： NIST SP 800-171 Rev 1 3.1.6 CIS Controls v7.1 4.3, 4.6 NIST CSF v1.1 PR.AC-4 NIST SP 800-53 Rev 4 AC-6(2) UK NCSC Cyber Essentials

種類名稱：控制內部系統存取(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 建立許可權最小化（Principle of Least Privilege, PoLP）原則，明確區分管理功能與一般非安全功能，確保非管理任務僅能透過非特權帳戶執行。 2. 實施角色存取控制（Role-Based Access Control, RBAC），針對不同作業職能配置對應的非特權角色，避免許可權過度擴張。

題目3，參考標準： NIST SP 800-171 Rev 1 3.1.18 CIS Controls v7.1 13.6, 16.7 NIST CSF v1.1 PR.AC-3, PR.AC-6 CERT RMM v1.2 TM:SG2.SP2 NIST SP 800-53 Rev 4 AC-19 UK NCSC Cyber Essentials

種類名稱：控制內部系統存取(顧問訂正前) **風險係數：** ⚠⚠⚠

資安改善建議： 1. 建立行動裝置註冊流程，要求所有連線公司網路的行動裝置須經由 IT 部門審核並完成資產註冊。 2. 匯入行動裝置管理（Mobile Device Management, MDM）解決方案，以落實對行動裝置的遠端監控與合規性檢查。

題目4，參考標準： NIST SP 800-171 Rev 1 3.1.3 CIS Controls v7.1 12.1, 12.2, 12.5, 12.8, 13.3, 14.1, 14.6, 14.7 NIST CSF v1.1 ID.AM-3, PR.AC-5, PR.DS-5, PR.PT-4 CERT RMM v1.2 TM:SG4.SP1 NIST SP 800-53 Rev 4 AC-4 UK NCSC Cyber Essentials

種類名稱：對授權的使用者與程式進行資料存取限制(顧問訂正前) **風險係數：**

資安改善建議： 1. 強化防火牆或代理伺服器（Proxy Server）的流量分析功能，建立異常流量偵測機制，確保能即時攔截非法的資料傳輸行為。

題目6，參考標準： NIST SP 800-171 Rev 1 3.4.6 NIST CSF v1.1 PR.IP-1, PR.PT-3 CERT RMM v1.2 TM:SG2.SP2 NIST SP 800-53 Rev 4 CM-7 UK NCSC Cyber Essentials

種類名稱：建立配置的基準(顧問訂正前) **風險係數：**

資安改善建議： 1. 建立系統匯入審核流程（System Onboarding Process），將「符合組織最低功能要求」納入新系統上線前的合規性檢查清單（Compliance Checklist）。 2. 由資訊部門（IT Department）針對新購或新部署之系統進行功能對照，確保其僅包含必要功能，避免冗餘功能增加攻擊面。

題目7，參考標準： NIST SP 800-171 Rev 1 3.4.2 CIS Controls v7.1 1.4, 1.5, 2.1, 2.4, 5.1 NIST CSF v1.1 ID.AM-1, ID.AM-2, PR.DS-3, PR.DS-7, PR.IP-1, DE.AE-1 CERT RMM v1.2 TM:SG2.SP2 NIST SP 800-53 Rev 4 CM-2, CM-6, CM-8, CM-8(1) UK NCSC Cyber Essentials

種類名稱：執行配置和變更管理(顧問訂正前) **風險係數：**

資安改善建議： 1. 參考業界標準（如 CIS Benchmarks）建立系統硬化（System Hardening）基準，針對不必要的服務、通訊協定與預設帳號進行關閉或停用。 2. 將上述嚴格配置納入標準化作業程式（Standard Operating Procedure, SOP），確保所有新部署的資訊系統皆能落實最小許可權原則。

題目8，參考標準： NIST SP 800-171 Rev 1 3.4.5 CIS Controls v7.1 2.5, 2.7, 2.8, 2.9, 4.3, 11.1, 11.3, 11.7 NIST CSF v1.1 PR.IP-1 CERT RMM v1.2 TM:SG4.SP1 NIST SP 800-53 Rev 4 CM-5 UK NCSC Cyber Essentials

種類名稱：執行配置和變更管理(顧問訂正前) **風險係數：**

資安改善建議： 1. 實施來源位址限制（Source IP Restriction），針對軟體更新（Software Update）服務設定僅允許來自特定管理站點或內部受信任 IP 段的存取。 2. 建立變更作業時間窗（Change Window）機制，將系統組態變更（Configuration Change）限制於非尖峰時段或經排程核准的時間區間內執行，以降低對業務運作的影響。

題目11，參考標準： FAR Clause 52.204-21 b.1.vi NIST SP 800-171 Rev 1 3.5.2 CIS Controls v7.1 4.2, 4.3, 16.8, 16.9 NIST CSF v1.1 PR.AC-1, PR.AC-6, PR.AC-7 CERT RMM v1.2 TM:SG4.SP1 NIST SP 800-53 Rev 4 IA-2, IA-3, IA-5 UK NCSC Cyber Essentials

種類名稱：授予經身份驗證的實體存取權限(顧問訂正前) **風險係數：**

資安改善建議： 1. 建立密碼管理政策，確保所有新建立的帳號與密碼皆為非預設值，避免使用系統初始密碼。 2. 強化密碼唯一性檢查機制，透過系統設定防止使用者重複使用舊有或重複的密碼，降低帳號遭破解後的風險。

題目13，參考標準： FAR Clause 52.204-21 b.1.x NIST SP 800-171 Rev 1 3.13.1 NIST CSF v1.1 PR.PT-4 NIST SP 800-53 Rev 4 SC-7 UK NCSC Cyber Essentials

種類名稱：在系統邊界控制通訊(顧問訂正前) **風險係數：**

資安改善建議： 1. 於防火牆或代理伺服器實施白名單（Whitelist）機制，限制僅允許存取經核准之可信任站點，以降低惡意通訊風險。 2. 部署網路封包側錄（Network Packet Capture, NPC）機制，針對關鍵內部邊界進行流量擷取，以利於資安事件發生時進行數位鑑識（Digital Forensics, DF）與追蹤。

題目14，參考標準： FAR Clause 52.204-21 b.1.xi NIST SP 800-171 Rev 1 3.13.5 CIS Controls v7.1 14.1 NIST CSF v1.1 PR.AC-5 NIST SP 800-53 Rev 4 SC-7 UK NCSC Cyber Essentials

種類名稱：在系統邊界控制通訊(顧問訂正前) **風險係數：**

資安改善建議： 1. 建立非軍事區（Demilitarized Zone, DMZ）以隔離公共存取系統與內部網路，確保外部流量無法直接觸及內部敏感資產。 2. 在 DMZ 與內部網路之間部署下一代防火牆（Next-Generation Firewall, NGFW），實施嚴格的存取控制清單（Access Control List, ACL）以限制流量。

題目18，參考標準： FAR Clause 52.204-21 b.1.xv NIST SP 800-171 Rev 1 3.14.5 CIS Controls v7.1 8.4, 8.7 NIST CSF v1.1 DE.CM-4 CERT RMM v1.2 VAR:SG3.SP1 NIST SP 800-53 Rev 4 SI-3

種類名稱：辨識惡意內容(顧問訂正前) **風險係數：**

資安改善建議： 1. 於端點防護軟體（Endpoint Protection, EP）設定即時掃描功能，確保在下載、開啟檔案或插入外部儲存裝置時，系統能自動觸發掃描機制。 2. 針對外部裝置（External Media）建立自動掃描策略，確保所有進入系統的檔案在執行前皆已透過惡意程式掃描。

題目19，參考標準： NIST SP 800-171 Rev 1 3.3.2 CIS Controls v7.1 16.8, 16.9 NIST CSF v1.1 DE.CM-1, DE.CM-3, DE.CM-7 CERT RMM v1.2 MON:SG1.SP3 NIST SP 800-53 Rev 4 AU-2, AU-3, AU-3(1), AU-6, AU-11, AU-12

種類名稱：定義稽核需求(顧問訂正前) **風險係數：**

資安改善建議： 1. 調整日誌記錄機制，確保系統在產生日誌時，能同步擷取並記錄通訊物件的目標 IP 地址（Destination IP Address），以建立完整的網路連線路徑追蹤能力。

題目20，參考標準： NIST SP 800-171 Rev 1 3.3.1 CIS Controls v7.1 6.2 NIST CSF v1.1. DE.CM-1, DE.CM-3, DE.CM-7 CERT RMM v1.2 MON:SG2.SP3 NIST SP 800-53 Rev 4 AU-2, AU-3, AU-3(1), AU-6, AU-11, AU-12

種類名稱：執行稽核(顧問訂正前) **風險係數：**

資安改善建議： 1. 於系統日誌（Log）中納入存取控制（Access Control, AC）之成功與失敗紀錄，確保包含使用者識別碼、存取時間及嘗試存取的資源資訊，以利於後續進行非法活動之調查與追蹤。

題目23，參考標準： NIST SP 800-171 Rev 1 3.2.1 CIS Controls v7.1 17.3

NIST CSF v1.1 PR.AT-1, PR.AT-2, PR.AT-3, PR.AT-4, PR.AT-5 CERT RMM v1.2 OTA:SG1.SP1 NIST SP 800-53 Rev 4 AT-2, AT-3

種類名稱：安全意識訓練(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 規劃年度資安週（Information Security Week, ISW）活動，將現有的講師培訓與海報宣導整合為系列化活動，例如舉辦資安演練或競賽，以提升員工參與度。

題目24，參考標準： NIST SP 800-171 Rev 1 3.2.2 CIS Controls v7.1 17.5, 17.6, 17.7, 17.8, 17.9

NIST CSF v1.1 PR.AT-1, PR.AT-2, PR.AT-3, PR.AT-4, PR.AT-5 CERT RMM v1.2 OTA:SG4.SP1 NIST SP 800-53 Rev 4 AT-2, AT-3

種類名稱：教育訓練(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 建立年度資安教育訓練預算編列機制，將資安專業培訓費用納入年度資訊安全計畫中，以確保培訓資源之持續性與穩定性。

題目25，參考標準： NIST SP 800-171 Rev 1 3.6.1 NIST CSF v1.1. RS.RP-1 CERT RMM v1.2 IMC:SG1.SP1

NIST SP 800-53 Rev 4 IR-2, IR-4

種類名稱：事件通報規劃(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 匯入數位鑑識（Digital Forensics, DF）工具以精確分析事件證據與發生路徑。 2. 建立與警察等執法機關（Law Enforcement Agency, LEA）的聯絡機制與通報流程。 3. 根據事件處理結果，定期更新事件處理政策（Incident Handling Policy）以最佳化流程。 4. 建立事後檢討（Post-Incident Review, PIR）機制，將經驗教訓轉化為改善措施。

題目29，參考標準： NIST CSF v1.1 DE.AE-2 CERT RMM v1.2 IMC:SG5.SP1 NIST SP 800-53 Rev 4 AU-2

種類名稱：執行事後審查(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 在現有的事件分析流程中，匯入因果圖（CED）作為結構化分析工具，協助調查人員系統性地梳理異常事件的潛在因素。 2. 針對重大資安事件，應要求調查小組利用 CED 找出根本原因（RCA），並將分析結果納入事件處理報告中，以強化事件後的補救措施。

題目31，參考標準： NIST SP 800-171 Rev 1 3.8.9 CERT RMM v1.2 MON:SG2.SP4 NIST 800-53 Rev 4 CP-9

種類名稱：復原管理(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 針對備份資料實施加密保護（Encryption, EN），確保資料在儲存（Data at Rest）與傳輸（Data in Transit）過程中，即使物理媒介遭竊或未經授權存取，內容仍無法被輕易解讀。

題目36，參考標準： NIST SP 800-171 Rev 1 3.12.1 NIST CSF v1.1 DE.DP-3 NIST SP 800-53 Rev 4 CA-2

種類名稱：定義和管理安全控制(顧問訂正前) **風險係數：** ⚠⚠

資安改善建議： 1. 建立安全控制評估紀錄，將防火牆、網段隔離等技術實作結果彙整為定期審核報告。 2. 針對評估中發現的弱點，應由資訊部門制定修復計劃（Remediation Plan, RP），明確修復時程與負責人。 3. 建立風險登記冊（Risk Register, RR），將評估過程中發現的新風險納入管理，以利進行風險評估與處理。

題目40，參考標準： FAR Clause 52.204-21 b.1.iii　NIST SP 800-171 Rev 1 3.1.20　CIS Controls v7.1 12.1, 12.4

NIST CSF v1.1 ID.AM-4, PR.AC-3　CERT RMM v1.2 EXD:SG3.SP1　NIST SP 800-53 Rev 4 AC-20, AC-20(1)

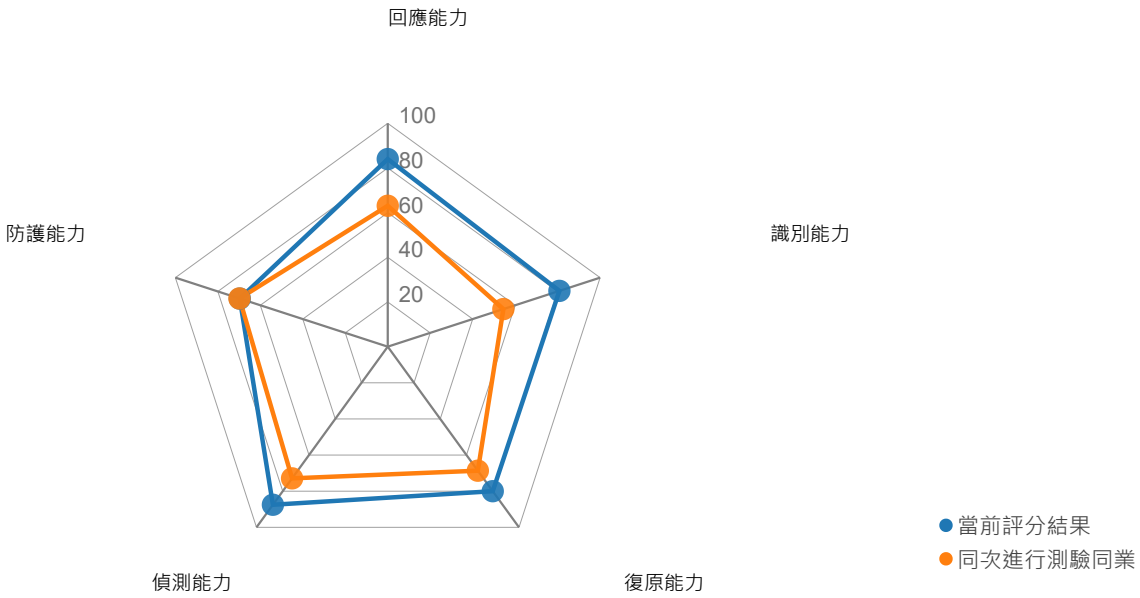
種類名稱：對授權的使用者與程式進行資料存取限制(顧問訂正前)　**風險係數：**

資安改善建議： 1. 建立個人裝置管理（Bring Your Own Device, BYOD）規範，透過行動裝置管理（Mobile Device Management, MDM）技術實施裝置認證與資料隔離。 2. 實施網路存取控制（Network Access Control, NAC）與防火牆規則，針對外部系統連線設定時間限制與連線方式限制。 3. 針對高風險職務或特定員工，實施最小許可權原則（Principle of Least Privilege, PoLP），透過防火牆或代理伺服器限制其內網與外部系統的連線路徑。

題目41，參考標準： FAR Clause 52.204-21 b.1.iv　NIST SP 800-171 Rev 1 3.1.22　NIST SP 800-53 Rev 4 AC-22

種類名稱：對授權的使用者與程式進行資料存取限制(顧問訂正前)　**風險係數：**

資安改善建議： 1. 建立資訊釋出審核流程（Information Review Process, IRP），針對所有即將釋出至公司網站或對外公開之資訊，應由非釋出者之主管或指定審核人員進行內容檢查，以確保資訊準確性並避免敏感資訊外洩。


回應能力
識別能力
復原能力
偵測能力
防護能力
100
80
60
40
20
當前評分結果
同次進行測驗同業